

Attacchi di Rete

NECKER

1 Dicembre 2025

Indice

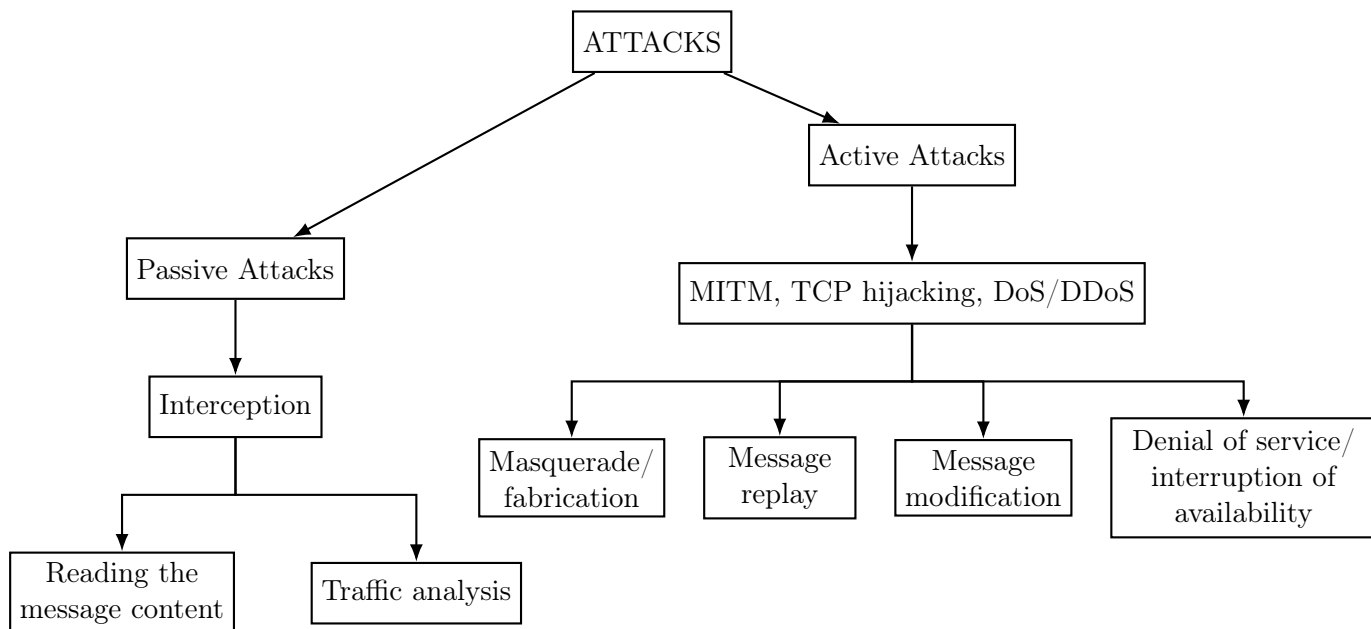
1	Classificazione degli Attacchi di Rete	2
2	Attacchi Passivi: Sniffing e Intercettazione Fisica	2
2.1	Sniffing (Intercettazione Passiva su Rete)	2
2.2	Intercettazione Fisica del Mezzo Trasmissivo	4
2.2.1	Intercettazione tramite Emissioni Elettromagnetiche (EM)	4
2.2.2	Intercettazione su Fibra Ottica	4
3	Attacchi Attivi di Manipolazione e Inganno (Spoofing e MITM)	5
3.1	Spoofing (Falsificazione dell'Identità)	5
3.2	Man-in-the-Middle (MITM)	6
3.3	DNS Pharming (Reindirizzamento Malevolo)	6
4	Attacchi di Negazione del Servizio (DoS/DDoS)	7
4.1	Attacchi per Saturazione di Banda e Protocollo	7
4.2	Attacchi per Saturazione Risorse (Resource Exhaustion)	7
4.3	Contromisure DoS/DDoS	8
5	Attacchi Avanzati: TCP Hijacking	9
5.1	TCP Hijacking – L'Attacco di Mitnick (1994)	9

1 Classificazione degli Attacchi di Rete

Schema Tassonomico Principale

Il panorama degli attacchi informatici si divide in due macro-categorie principali: attacchi Passivi (intercettazione) e attacchi Attivi (modifica o generazione di traffico).

Tassonomia degli Attacchi di Rete



2 Attacchi Passivi: Sniffing e Intercettazione Fisica

2.1 Sniffing (Intercettazione Passiva su Rete)

Definizione e Funzionamento

Lo **Sniffing** è la tecnica di cattura e analisi dei pacchetti di dati che transitano su un segmento di rete (quindi applicabile solo se si è nella stessa rete). Viene definita **intercettazione passiva** poiché l'attaccante si limita ad **ascoltare** il traffico esistente senza modificarlo o generare nuovi pacchetti per ingannare i sistemi (a differenza dello Spoofing).

- L'attaccante utilizza un software **sniffer** (o analizzatore di pacchetti) che mette la propria scheda di rete (NIC) in **modalità promiscua** (*promiscuous mode*).
- In *modalità promiscua*, la scheda riceve ed elabora **tutti i pacchetti** che passano sul segmento di rete, non solo quelli destinati al proprio indirizzo MAC.
- L'attacco è più efficace su reti che utilizzano **Hub** (che inoltrano tutti i pacchetti a tutti), ma su reti basate su **Switch** moderni, è necessario combinare lo sniffing con una tecnica attiva (come l'ARP Spoofing) per reindirizzare il traffico.

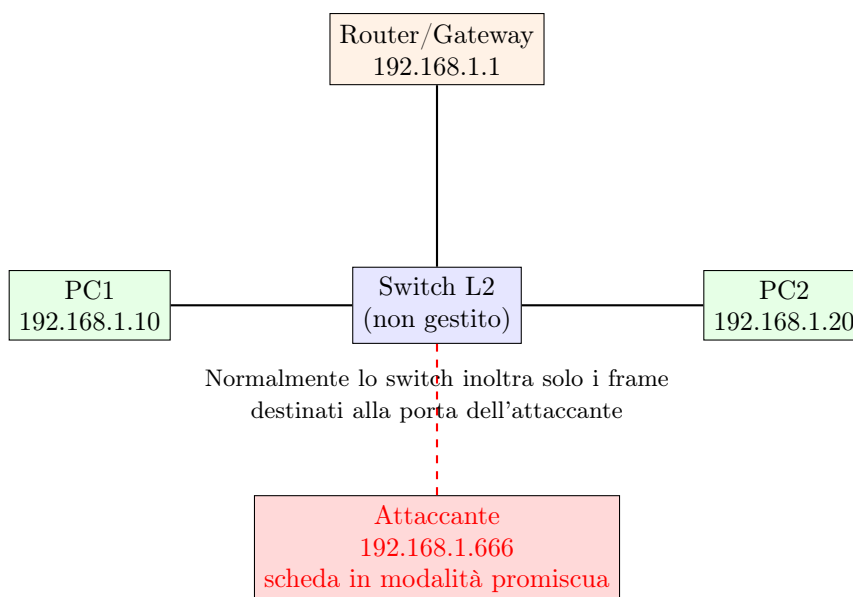
ATTENZIONE: generalmente comunque i dati che passano non sono mai in chiaro ma sono criptati (se la rete è ben configurata).

Obiettivi

L'obiettivo primario dello Sniffing è la raccolta di informazioni:

1. **Cattura di Credenziali:** Intercettare nomi utente e password trasmesse in chiaro (su protocolli non cifrati come HTTP, FTP, Telnet).
2. **Analisi del Protocollo:** Studiare il comportamento della rete, i protocolli in uso e identificare gli indirizzi IP e MAC degli host.
3. **Intercettazione Dati:** Acquisire il contenuto di comunicazioni, documenti o informazioni sensibili.

Esempio: Sniffing su Rete non Gestita



Tecniche e Strumenti per Sniffing su Switch

Tecniche per Abilitare lo Sniffing su Switch

Tecnica	Descrizione
ARP Poisoning	La più usata. Avvelena la cache ARP delle vittime → l'attaccante diventa Man-in-the-Middle.
MAC Flooding	Riempie la tabella CAM con MAC falsi → switch in modalità fail-open (si comporta come hub).
Port Mirroring (SPAN/RSPAN)	Configurazione amministrativa legittima che duplica il traffico su una porta di monitoraggio.
Hub fisico	Tutti i dispositivi vedono tutto il traffico (praticamente estinti).
Network TAP (usato dalla polizia)	Dispositivo hardware passivo che duplica fisicamente il flusso.

Dopo l'attacco: tutto il traffico tra vittima e gateway passa dall'attaccante.

Strumenti di Analisi dei Pacchetti

Strumento	Note
Wireshark	GUI più potente al mondo, filtri display avanzati
tcpdump / tshark	Ideali su server headless e script
ettercap	Specializzato in ARP spoofing + sniffing integrato
BetterCAP	Framework moderno (supporta anche Wi-Fi, BLE, HTTP/2, ecc.)
arp spoof (dsniff)	Classico, ancora funzionante
cain (Windows)	Tutto-in-uno storico su Windows

2.2 Intercettazione Fisica del Mezzo Trasmissivo

L'intercettazione passiva non si limita all'analisi dei pacchetti a livello software, ma sfrutta anche le proprietà fisiche dei cavi e delle trasmissioni.

2.2.1 Intercettazione tramite Emissioni Elettromagnetiche (EM)

Tutti i dispositivi elettronici e i cavi di rete non schermati o con schermatura insufficiente (*cavi UTP*) emettono radiazioni elettromagnetiche residue che trasportano il segnale di dati.

- **Tecnica:** L'attaccante utilizza ricevitori ad alta sensibilità e antenne direzionali per catturare queste emissioni a distanza.
- **Obiettivo:** Decodificare il segnale EM per ricostruire il flusso di dati trasmesso attraverso il cavo (metodo non invasivo).
- **Difesa:** Implementazione della metodologia **TEMPEST** (Telecommunications Electronics Material Protected from Emanating Spurious Transmissions), che prescrive standard rigorosi di schermatura (*cavi STP*) e gabbie di Faraday per impedire la fuoriuscita delle emissioni.

2.2.2 Intercettazione su Fibra Ottica

Le trasmissioni su fibra ottica (che utilizzano la luce per trasportare i dati) sono generalmente considerate più sicure perché non emettono radiazioni elettromagnetiche, ma possono comunque essere intercettate passivamente se si accede al cavo.

- **Tecnica:** Viene utilizzato un attacco non distruttivo come la **Micro-bending** o l'uso di un **optical splitter** (divisore ottico).
- **Micro-bending:** Piegando leggermente e con precisione il cavo in fibra (senza romperlo), è possibile deviare una minima quantità di luce (pochi fotoni) che trasporta il segnale. Questo segnale deviato viene poi catturato e amplificato da un ricevitore ottico ad alta sensibilità.
- **Vantaggio:** L'attacco è **passivo** e **stealth** (nascosto), poiché la piccola perdita di luce non è sufficiente ad attivare gli allarmi di monitoraggio della potenza del segnale sulla rete.

3 Attacchi Attivi di Manipolazione e Inganno (Spoofing e MITM)

3.1 Spoofing (Falsificazione dell'Identità)

Definizione e Scopo

Lo **Spoofing** è una categoria di attacchi informatici in cui un aggressore **falsifica la propria identità** fingendo di essere un'entità, un dispositivo o una fonte fidata e legittima. Lo scopo primario è l'inganno, finalizzato a bypassare i controlli di sicurezza, ottenere accesso non autorizzato o rubare dati sensibili.

- A differenza dello Sniffing (passivo), lo Spoofing è un attacco **attivo**, poiché l'attaccante genera e invia dati modificati per ingannare la vittima o la rete.
- L'efficacia dello Spoofing risiede nello sfruttare la **fiducia implicita** nei protocolli di rete o la **fiducia umana** (Ingegneria Sociale).

Tipologie Comuni di Spoofing

Lo Spoofing si manifesta in diverse forme, a seconda del livello di comunicazione che viene falsificato:

ARP Spoofing (Address Resolution Protocol)

- **Cosa Falsifica:** Associa un indirizzo **MAC** falso (quello dell'attaccante) a un indirizzo **IP** legittimo (ad esempio, quello del router o di un altro host) all'interno di una rete locale (LAN).
- **Effetto:** Inganna gli altri dispositivi della rete facendoli credere che il percorso corretto per quell'IP passi attraverso la macchina dell'attaccante. Ciò consente l'intercettazione completa del traffico (**Man-in-the-Middle**).
- **Come:** dato che i dispositivi sulla stessa rete si individuano tra loro attraverso l'indirizzo **MAC** e dato che ogni pc ha una tabella **stateless** (cioè non si ricorda se le info cambiano nel tempo), basterà una singola richiesta **ARP** malevola per far cambiare il **MAC** associato a un **ip**.
- **Contromisura:** si implementano ove possibile le **ARP statiche**, ovvero le **ARP**, vengono inserite manualmente dall'amministratore di sistema e non possono essere aggiornate automaticamente dal traffico ARP dinamico.

IP Spoofing (Internet Protocol)

- **Cosa Falsifica:** Sostituisce l'indirizzo IP di origine nell'intestazione di un pacchetto di rete con un **indirizzo IP falso**.
- **Effetto:** Nasconde l'identità reale dell'attaccante e può essere usato per aggirare i filtri di rete che autorizzano solo specifici IP; è spesso utilizzato negli attacchi **Distributed Denial of Service (DDoS)** per mascherare i bot.
- **Come:** si modifica l'ip contenuto nell'**header** del pacchetto.

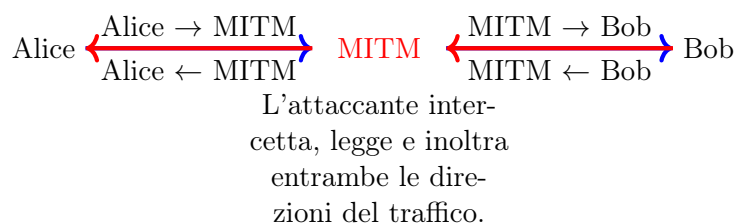
Email Spoofing

- **Cosa Falsifica:** Modifica l'intestazione di un messaggio di posta elettronica per visualizzare un indirizzo **mittente** diverso e apparentemente legittimo.
- **Effetto:** È la base per le campagne di **Phishing** o **Spear-Phishing**, volte a convincere il destinatario a fornire credenziali o trasferire fondi.
- **Come:** L'aggressore utilizza un software o un server SMTP configurato per specificare un indirizzo email nel campo From: (Mittente) diverso dal suo indirizzo reale.

3.2 Man-in-the-Middle (MITM)

L'attacco **Man-in-the-Middle** (MITM) è una forma di intercettazione attiva in cui l'aggressore si interpone segretamente tra due parti che comunicano, intercettando e potenzialmente modificando tutti i messaggi che passano tra di loro senza che le parti lo sappiano.

- **Meccanismo:** L'attaccante funge da relé, facendo credere ad Alice di comunicare direttamente con Bob, e a Bob di comunicare direttamente con Alice.
- **Scopo:** Intercettare credenziali, modificare transazioni o rubare informazioni crittografiche prima che vengano protette.
- **Implementazione comune:** In una rete locale, viene spesso realizzato tramite **ARP Spoofing** o **DNS Spoofing** per reindirizzare il traffico.



3.3 DNS Pharming (Reindirizzamento Malevolo)

Il **Pharming** è una tecnica di frode che mira a **reindirizzare** gli utenti da un sito web legittimo a un sito fasullo senza che se ne accorgano, anche se digitano l'URL corretto. Lo Spoofing viene utilizzato per falsificare le risposte del servizio di risoluzione nomi (DNS).

- **Meccanismo:** Viene manipolato il processo di risoluzione del nome di dominio (URL) nell'indirizzo IP del server.
- **Tipologie di Reindirizzamento Malevolo:**
 1. **Modifica del File Hosts:** L'attaccante infetta la macchina locale della vittima e modifica il file `hosts`, forzando il browser a risolvere il nome di dominio legittimo (es. `banca.com`) verso un IP malevolo.
 2. **DNS Cache Poisoning:** L'attaccante inietta dati falsi nella cache del server DNS, facendo credere al server che l'IP del dominio target sia quello del sito fasullo controllato dall'aggressore. Tutti gli utenti che interrogheranno quel server DNS verranno reindirizzati (per farlo l'attaccante invia molti pacchetti con ip malevolo collegato al dominio cercando di convincere il **DNS** che è un ip legit).
 3. **Router Compromesso:** L'attaccante compromette il router di rete e ne modifica le impostazioni per usare un server DNS malevolo.

4 Attacchi di Negazione del Servizio (DoS/DDoS)

Gli attacchi **Denial of Service** e **Distributed Denial of Service (DDoS)** mirano a rendere non disponibile un servizio o una risorsa di rete sovraccaricando il sistema vittima con un volume eccessivo di traffico generato da una singola sorgente o da sorgenti multiple e distribuite (spesso una *botnet*). L'obiettivo è consumare risorse vitali come banda, CPU, memoria o tabelle di connessione.

4.1 Attacchi per Saturazione di Banda e Protocollo

- **Ping of Death**

- **Tecnica:** Invio di un pacchetto **ICMP Echo Request** (ping) con una dimensione superiore al massimo consentito per il protocollo IP (**maggiore di 65535 byte**).
- **Effetto:** Quando i sistemi operativi meno recenti tentavano di riassemblare il pacchetto frammentato, il buffer overflow causava il crash o il riavvio del sistema. (Nota: questo attacco è ampiamente **patchato** nei sistemi operativi moderni ma ancora possibile su **Windows 7**).
- **Come:** l'OS allocava un buffer in memoria per riassemblare il pacchetto, esso però poteva sbuffare e subito dopo erano presenti strutture cruciali per il funzionamento del sistema operativo stesso.

- **Smurf**

- **Tecnica:** L'attaccante invia un pacchetto ICMP Echo Request (ping) con l'indirizzo IP sorgente **falsificato** (*spoofed*) con l'indirizzo IP della vittima. Questo pacchetto viene inviato all'indirizzo di **broadcast** di una rete intermedia.
- **Effetto:** Tutti gli host di quella rete intermedia rispondono simultaneamente alla vittima, amplificando il traffico in modo massivo. (Attacchi mitigati dal blocco dell'inoltro broadcast sui router).

- **LAND (Local Area Network Denial)**

- **Tecnica:** Invio di un pacchetto **TCP SYN** in cui l'indirizzo **IP sorgente** (**src IP**) e l'indirizzo **IP destinazione** (**dst IP**) sono **uguali** (l'indirizzo della vittima).
- **Effetto:** Il sistema vittima entra in un loop infinito cercando di rispondere al proprio indirizzo, consumando risorse e causando il crash del sistema operativo o del servizio. (Attacco ampiamente **patchato**).

- **SYN Flooding**

- **Tecnica:** L'attaccante invia una sequenza massiva di pacchetti **TCP SYN** con indirizzi IP sorgente spesso **falsificati** (*spoofed*).
- **Effetto:** Per ogni SYN ricevuto, il server vittima alloca risorse in una struttura chiamata **backlog** in attesa del pacchetto **ACK** per completare l'handshake a tre vie (SYN, SYN-ACK, ACK). Poiché l'attaccante non invia mai l'ACK (o non riceve il SYN-ACK a causa dell'IP spoofed), il backlog del server si riempie rapidamente, impedendogli di accettare nuove connessioni legittime.

4.2 Attacchi per Saturazione Risorse (Resource Exhaustion)

Saturazione del File System (Attacco ai Firewall)

Questi attacchi non mirano a saturare la banda di rete o la tabella delle connessioni, ma a esaurire le risorse di archiviazione o di memoria del dispositivo di difesa (come un firewall o un router) o del sistema operativo, causandone il blocco o il crash.

- **Obiettivo:** Saturare lo spazio su disco o la partizione di log del firewall, rendendo impossibile la scrittura di nuovi eventi di sicurezza.
- **Tecnica:** L'attaccante invia un volume estremamente elevato di pacchetti che il firewall deve **negare** e **registrare** (loggere).
 - Spesso si usano pacchetti **UDP** o **ICMP** destinati a porte o indirizzi non esistenti.
 - Il firewall, seguendo la sua policy di sicurezza, genera un **messaggio di errore** (es. ICMP Destination Unreachable) per ogni pacchetto negato e, contemporaneamente, **scrive un log** dell'evento.
 - Se la velocità di generazione dei pacchetti supera la capacità del firewall di scriverli nel log, la memoria temporanea (buffer) per i log si riempie, e in alcuni sistemi, il file system di logging può saturarsi rapidamente.
- **Effetto:** Quando il file system del firewall è pieno, questo può smettere di funzionare correttamente, riavviarsi, o interrompere il logging, impedendo agli amministratori di rilevare altri attacchi.

4.3 Contromisure DoS/DDoS

- **SYN Cookies:** Meccanismo efficace contro il SYN Flooding. Il server risponde al SYN con un SYN-ACK che contiene un **cookie crittografico** invece di allocare immediatamente spazio nel backlog. L'allocazione delle risorse avviene solo se e quando riceve l'ACK finale valido contenente il cookie, dimostrando che si tratta di una connessione legittima (nel cookie ci sono tutte le info necessarie per evitare di allocare prima del dovuto).
- **Egress Filtering:** Implementazione di filtri in uscita sulle reti (es. presso gli ISP) per impedire l'invio di pacchetti con indirizzi IP sorgente non appartenenti alla rete locale, mitigando così l'uso di IP Spoofing negli attacchi.
- **Limiti di Tasso (Rate Limiting):** Limitare il numero di richieste per protocollo (es. TCP SYN) accettate da un singolo indirizzo IP o da una specifica sorgente in un dato intervallo di tempo.
- **Firewall:** usati per limitare il traffico malevolo in entrata.

5 Attacchi Avanzati: TCP Hijacking

5.1 TCP Hijacking – L’Attacco di Mitnick (1994)

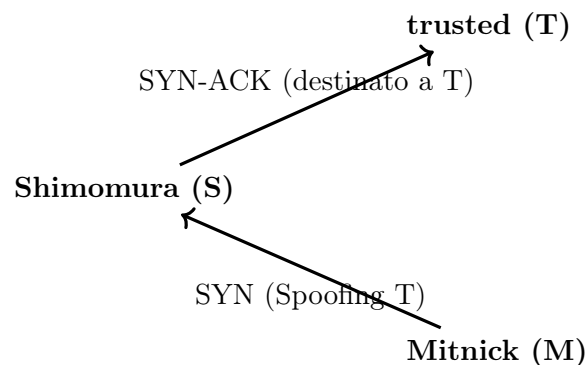
Il **TCP Hijacking** è l’atto di assumere il controllo di una sessione TCP stabilita e autenticata tra due host. L’attacco di Kevin Mitnick contro Tsutomu Shimomura nel 1994 è l’esempio più famoso di **IP Spoofing** combinato con la **Previsione del Sequence Number** per dirottare una sessione fidata.

Contesto e Obiettivo

L’attacco si basava su una **relazione di fiducia** (*trust relationship*) tra due macchine di Shimomura:

- **Shimomura (S)**: Il computer bersaglio principale, a cui Mitnick voleva accedere (**Server** `rsh`).
- **Trusted Host (T)**: Un computer fidato che poteva connettersi a S ed eseguire comandi (es. `rsh`: Remote Shell) senza richiedere una password (**Client** fidato).

L’obiettivo di Mitnick (M) era impersonare l’host fidato (T) per stabilire una sessione `rsh` con S e ottenere i permessi di root (per poi installare una back door su S e operare da lì).



NOTA: L’attacco storico ha sfruttato la *prevedibilità* dell’Initial Sequence Number (ISN) generato dal sistema operativo SunOS del computer S.

Passaggi Dettagliati dell’Attacco

L’attacco è stato un capolavoro di ingegneria sociale e tecnica, composto da cinque fasi cruciali:

1. **Raccolta Informazioni (con comandi come `finger @S` e `showmount -e`):** Mitnick ha usato comandi di rete standard per raccogliere dati sul sistema S, inclusi gli utenti attivi (per attaccare quando non c’era nessuno) e il sistema fidato T.
2. **Disattivazione dell’Host Fidato (T):** L’attaccante inonda l’host T con pacchetti **SYN Flood** per saturare la sua tabella delle connessioni (il *backlog*) e renderlo temporaneamente incapace di rispondere a nuove richieste. Questo passaggio è cruciale affinché l’host T non invii un pacchetto **RST** (reset) quando riceve il **SYN-ACK** destinato a lui, infatti, se T ricevesse una **SYN-ACK** anomala, invierebbe una risposta **RST** per far interrompere la connessione.
3. **Previsione del Sequence Number (ISN):** Mitnick ha inviato pacchetti **SYN** a S e analizzato i relativi **SYN-ACK** per comprendere il **pattern** di generazione degli Initial Sequence Number (ISN) del sistema operativo di S. Una volta identificato il pattern (all’epoca era prevedibile), ha potuto calcolare l’ISN che S avrebbe usato nella risposta successiva.

4. **Iniezione di Sessione (IP Spoofing):** Mitnick invia a S un pacchetto **SYN** con l'indirizzo IP **sorgente falsificato** come se fosse l'host fidato T (IP Spoofing).
 - S risponde inviando un pacchetto **SYN-ACK** all'indirizzo IP spoofato (T).
 - Poiché T è inattivo (a causa del SYN flood), non riceve o non processa il pacchetto SYN-ACK.
5. **Completamento dell'Handshake e Comando:** Mitnick invia un pacchetto **ACK** a S utilizzando l'IP spoofato di T e specificando il Sequence Number previsto ($ISN + 1$) per completare l'handshake TCP a tre vie fittizio. A questo punto, S crede che sia stata stabilita una sessione legittima con T. L'attaccante può quindi iniettare comandi (come **rsh** per creare una backdoor) che S esegue con i privilegi dell'host fidato.

Contromisure Attuali

L'attacco di Mitnick ha evidenziato una grave debolezza nel protocollo TCP. Oggi, l'attacco è quasi **impossibile** da replicare in questo modo perché:

- I sistemi operativi moderni **randomizzano** in modo robusto gli Initial Sequence Number (ISN), impedendo la previsione.
- Le relazioni di fiducia basate esclusivamente sull'indirizzo IP (come **rsh**) sono state in gran parte abbandonate a favore di meccanismi di autenticazione più sicuri (come SSH).